

BÁO CÁO LAB 8

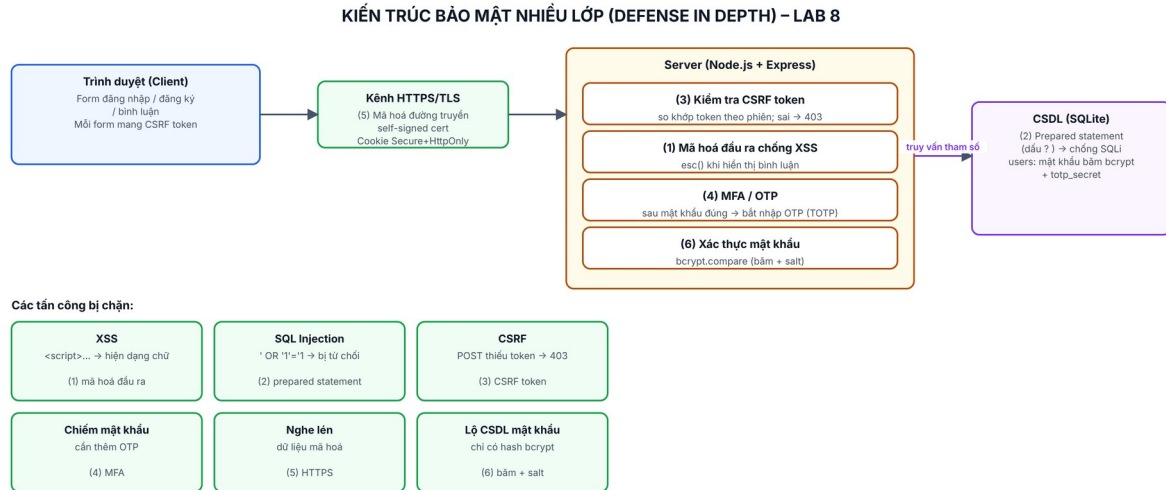
BẢO VỆ AN TOÀN THÔNG TIN CHO ỨNG DỤNG WEB

Họ tên: UNG VẴNG ĐẠI LÂM MSSV: 2380601202 Lớp: 23DATA1

Hình thức: Cá nhân. Mã nguồn: github.com/UngVangDaiLam/ATw-CSDL_Lab (thư mục lab8).

1. Môi trường

Ứng dụng web **Node.js + Express + SQLite** (`app/`) với các chức năng **đăng ký, đăng nhập, bình luận**. Trên nền đó, bài tập áp dụng đồng thời 7 biện pháp bảo mật và kiểm thử từng biện pháp bằng cách thử tấn công và xác nhận bị chặn (Hình 3). Chạy: `cd app` → `npm install` → tạo chứng chỉ (xem README) → `npm start` → mở `https://localhost:8443`. Tài khoản demo: **user1 / Pass123!** (đã bật MFA).



Hình 1. Kiến trúc bảo mật nhiều lớp của ứng dụng

2. Các biện pháp đã triển khai và lý do

#	Biện pháp	Cách làm & tại sao cần
1	Chống XSS	Mã hoá đầu ra (esc tương đương htmlspecialchars) khi hiển thị bình luận → script của kẻ tấn công chỉ hiện dạng chữ, không chạy trong trình duyệt nạn nhân.
2	Chống SQL Injection	Dùng prepared statement (dấu ?) cho mọi truy vấn → dữ liệu không trộn vào cú pháp SQL, payload "' OR '1'='1" vô hại.
3	CSRF Token	Sinh token theo phiên, nhúng vào mọi form, xác minh ở server → chặn yêu cầu giả mạo từ trang khác thay mặt người dùng.
4	MFA / OTP	Sau khi mật khẩu đúng, bắt nhập OTP 6 số (TOTP – Google Authenticator) → lộ mật khẩu vẫn chưa đủ để đăng nhập.
5	HTTPS	Chạy trên TLS (self-signed cert), cookie Secure + HttpOnly + SameSite → chống nghe lén và đánh cắp cookie phiên.
6	Băm mật khẩu	Lưu mật khẩu bằng bcrypt + salt (cost 10), so khớp bằng bcrypt.compare → lộ CSDL cũng không đọc được mật khẩu gốc.

3. Kết quả kiểm thử (tấn công bị chặn)

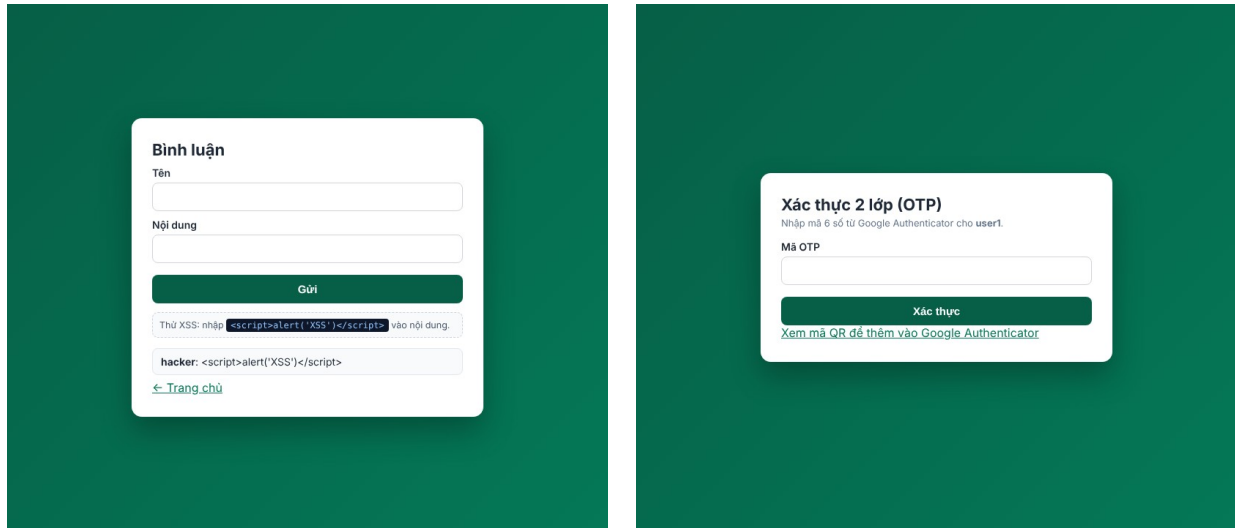
Mình thử từng tấn công trên ứng dụng (qua HTTPS) và xác nhận đều bị chặn:

KET QUẢ KIỂM THU CÁC BIỆN PHÁP BẢO MẬT (chạy qua HTTPS localhost:8443)

```
(3) CSRF : POST /login THIẾU token -> HTTP 403 CHẶN CSRF
(2) SQLi : /login voi ' OR '1'='1 -> BI TU CHỖI (prepared statement vô hiệu hoá)
(6) bcrypt: đăng nhập dung mat khau -> chuyen sang buoc OTP (so khop bang bcrypt.compare)
(4) MFA : truy cap sau mat khau -> YEU CAU NHAP OTP (Google Authenticator)
(4) MFA : nhap OTP dung -> DANG NHAP HOAN TAT (qua 2 lop)
(1) XSS : binh luan <script>alert(1)</script> -> luu & hien dang &lt;script&gt; (ĐA MA HOA)
(6) Lưu : mat khau trong DB = $2b$10$... (bcrypt hash + salt, KHÔNG phai plaintext)
(5) HTTPS: server chay tren https://localhost:8443 (self-signed certificate)
```

Hình 2. Kết quả kiểm thử tự động: tất cả tấn công đều bị chặn

Tấn công thử	Đầu vào	Kết quả
SQL Injection	username = ' OR '1'='1	Bị từ chối – không đăng nhập được
XSS (stored)	bình luận <script>alert('XSS')</script>	Lưu & hiển thị dạng <script> – không chạy
CSRF	POST /login thiếu token	HTTP 403 – bị chặn
Thiếu lớp 2	đúng mật khẩu, chưa có OTP	Bắt buộc nhập OTP mới vào được



Hình 3. Trái: bình luận XSS bị mã hoá thành chữ. Phải: sau mật khẩu đúng phải nhập OTP (MFA).

Minh hoạ mã nguồn hai lớp quan trọng:

```
// (2) SQLi + (6) bcrypt: tìm user bằng prepared statement, so khớp hash
const row = db.prepare('SELECT * FROM users WHERE username = ?').get(username);
if (!row || !bcrypt.compareSync(password, row.pass_hash)) return reject();
// (1) XSS: mã hoá trước khi in bình luận ra HTML
`<li><b>${esc(c.author)}</b>: ${esc(c.content)}</li>`
```

4. Hạn chế và đề xuất cải thiện

- **Chứng chỉ tự ký (self-signed):** trình duyệt cảnh báo; thực tế nên dùng chứng chỉ từ CA (Let's Encrypt) và bật HSTS.
- **Dữ liệu trong RAM:** demo dùng SQLite in-memory, mất khi tắt server; thực tế dùng CSDL bền vững và sao lưu.
- **MFA secret & khôi phục:** cần quy trình bật/tắt MFA an toàn, mã khôi phục (backup codes), chống dò OTP.
- **Thiếu rate limit & khoá tài khoản** cho đăng nhập/OTP (nên thêm như Lab 5), cùng ghi log và giám sát.
- **Nên bổ sung:** Content Security Policy, security headers (helmet), lọc HTML bằng DOMPurify nếu cho phép định dạng, và mã hoá dữ liệu nhạy cảm khi lưu (at-rest).

5. Kết luận

Ứng dụng đã áp dụng phòng thủ nhiều lớp: bấm mật khẩu, truy vấn tham số, mã hoá đầu ra, CSRF token, MFA và HTTPS. Kiểm thử cho thấy các tấn công XSS, SQL Injection và CSRF đều bị chặn, và việc lộ mật khẩu đơn lẻ không đủ để vượt qua MFA. Không có biện pháp đơn lẻ nào là đủ; an toàn thông tin đạt được nhờ kết hợp nhiều lớp bảo vệ, cùng giám sát và cập nhật thường xuyên.